

CyberShield IT Security Policy 2025: Strategic Framework for PakTech Medical Systems Cybersecurity & Data Protection Policy

CONTENTS

CHAPTER 1-PRELIMINARY

- 1.1 COMMENCEMENT**
- 1.2 APPLICATIONS OF THE POLICY**
- 1.3 DEFINITIONS**
- 1.4 SCOPE AND OBJECTIVES**
- 1.5 OVERVIEW**

CHAPTER 2-INTRODUCTION

- 2.1 POLICY PRINCIPLES**
- 2.2 SECURITY PRINCIPLES**
- 2.3 POLICY IMPLEMENTATION**
- 2.4 POLICY OWNERSHIP**
- 2.5 GUIDING VALUES**

CHAPTER 3-ROLES AND RESPONSIBILITIES

- 3.1 SENIOR MANAGEMENT**
- 3.2 INFORMATION SECURITY OFFICER (ISO)**
- 3.3 IT SECURITY TEAM**
- 3.4 DEPARTMENT HEADS**
- 3.5 EMPLOYEES**

CHAPTER 4-SECURITY CONTROLS

- 4.1 ACCESS CONTROL**
- 4.2 NETWORK SECURITY**
- 4.3 CHANGES AND UPDATES TO REGULATIONS**
- 4.4 REPORTING TO ISO AND ESCALATION OPTIONS**
- 4.5 ACCOUNTIBILITY**
- 4.6 INFORMATION MANAGING PROCEDURES**

CHAPTER 5-ASSEST MANAGEMENT AND IDENTIFICATION

- 5.1 ASSEST TRACKING PURPOSE AND RELEVANCE**
- 5.2 ASSETS INCLUDED IN THE INFORMATION ENVIROMENT**
- 5.3 DIGITAL ASSETS AND DATA TAXONOMY**
- 5.4 ASSET LABELING**
- 5.5 RISK PROTECTION, ALIGNMENT AND CONTROL**

CHAPTER 6-COMPLIANCE, INVESTIGATION AND ENFORCEMENT

- 6.1 LEGAL AND REGULATORY COMPLAINCE**
- 6.2 ETHICAL REQUIRMENTS AND INTERNAL COMPLAINCE STANDARDS**
- 6.3 INTERNAL AUDIT PRACTICE AND MONITORING PROCEDUERS**
- 6.4 DATA BREACH AND INCIDENT RESPONSE**
- 6.5 RESEARCH PROCEDURES AND INCIDENT ESCALATION PROCESS**
- 6.6 VERSION CONTROL AND POLICY REVIEW SCHEDULE**

CHAPTER 7-MISUSE AND PENALTIES FRAMEWORK

- 7.1 DEFINATION OF MISUSE**
- 7.2 TYPES OF VIOLATIONS**
- 7.3 PENALTY STRUCTURE**
- 7.4 DISCIPLINARY PROCESS**
- 7.5 APPEAL AND RESOLUTION MECHANISM**
- 7.6 EDUCATION AND PREVENTION**

CHAPTER 1 (PRILIMINARY)

1.1 Title and Extent:

The document shall henceforth be known as the “**Cybersecurity and Data Protection Policy of PakTech Medical Systems**”. It is responsible for directing how IT assets, systems, and data in the organization are utilized, accessed, defended, and managed. Everyone using devices, systems, services, or working on the network within the organization is bound by this policy.

1.2 Commencement

The senior management and IT governance committee of PakTech Medical Systems shall approve this policy as of May 1, 2025. Once this policy receives approval, it goes into effect immediately and will be updated and reviewed as needed to address new risks, new technologies and changes in compliance rules.

1.3 Application of The Policy

All operations within Pak Tech Medical Systems include this policy, with the amount of use and type of implementation differing from one functional sector to another, depending on what they do, who can access data and the sensitivity of the data involved. Staff members in Clinical and Medical Services must strictly follow rules about protecting patient data, controlling access and using systems according to relevant healthcare compliance rules. Because they handle **Electronic Health Records (EHR)** and other sensitive medical systems. Following are the applications applied:

- These departments need to make sure that billing records, payroll files, data on insurance and vendor details are safely maintained. ID proving, separating system access and ensuring transaction safety are the main focuses of controls.
- Because IT and Technical teams can access privileged systems, they must follow the strongest security regulations. They install, run and track technologies, monitor their activities and ensure their infrastructure is robust.
- Access to Contractors and Third-Party Vendors is only given when and where the contract requires it. Everyone with access to data outside the organization must observe the rules about handling, accessing and moving information set out in security agreements with third parties.

- Only specific people, called Support and Maintenance Staff, are allowed into critical systems or assets and all their actions are monitored on-the-spot to protect against wrongdoing.
- the policy must be implemented no matter if the environment is on-premises, in the cloud, used remotely or at an associated medical facility. Operator-specific measures are used based on how high a sector's risks and operational challenges are.

1.4 Definitions:

1. PakTech IT System refers to the Sensitive Data stored or transmitted within PakTech IT systems that are related to patient's personal identifiable information (PII), medical records, financial, or treatment history.
2. **Cyber threat:** Any incident involving an unauthorized use of IT system/network or data that violates a confidentiality, integrity or availability. Breach, unauthorized access, malware attacks, among other forms of cyber threats.
3. **Acting:** Also simply referred to as acting, which is a synonym to compliance, which is the act of adhering to applicable legal, regulatory, and industry standards such as ISO 27001, HIPAA (local healthcare industry standards), or GDPR, as well as internal organizational policies.
4. **Cyber Threat Intelligence:** Information and analysis regarding current or potential cyber threats to PakTech's systems and sensitive data for which we generate, and maintain the integrity of the data, to identify, monitor, and mitigate those threats.
5. **Disaster Recovery (DR):** Recovery of IT infrastructure and the critical data after a cyber incident or disaster, to restore IT / business continuity with as short a period of downtime as possible.
6. **Security Measures:** PakTech implements security measures to protect packets on its networks into unauthorized access such as firewalls, IDS or Intranet Protection System and secure communications protocol.
7. **Data Encryption:** A technique of transforming information to an undecipherable structure to avoid access of unauthorized people. Crypto also includes encryption of data both in transit and at rest.
8. External companies or individuals who provide services to PakTech, outside of the company and may have access to the company's system, data, or network either directly or indirectly.

9. This is Incident response, which is a formal process of providing response and management of cyber security incidents, Containment, eradication of threats, recovery of systems and notification procedures.
10. Security Measures that prevent the access of sensitive system or the data by restricting the access to such sensitive data only to authorized users. Because of this, it includes the use of **Role-Based Access Controls (RBAC)**, **Multi Factor Authentication (MFA)**, and least privilege access.

1.5 OVERVIEW

As a strategic and operational priority, springing this context of information security is needed by any modern organizations which have important and confidential information to conduct their business. This policy has the intent of developing a comprehensive policy of managing organization digital assets security. It is developed by CyberShield Solutions, a Cyber Security leader at Karachi, Pakistan. The policy aims at the rules, standards and responsibilities for protecting the critical information systems from either internal or external threats.

1.6 OBJECTIVES

The goal of this policy is to guarantee security, compliance, and strength in IT systems that shield the company's assets and ensure no sensitive data is leaked, while ensuring all important services are continually available. It also pays attention towards the infrastructure defense and data protection to all aspects in cybersecurity, and is based on international standards (**ISO 27001, NIST**), and in line with the National law especially **Protection of Electronic Crimes Act (PECA) 2016**. It guarantees that security is furthermore reactive and repairable in the case of a disaster. The core objectives of this security policy are to:

- Protect sensitive personal and medical data from unauthorized access, alteration, or destruction.
- Establish roles, responsibilities, and procedures for managing IT security incidents and breaches.
- Define preventive, detective, and responsive security controls.
- Promote a culture of cybersecurity awareness and resilience within the organization.
- Support business continuity through secure infrastructure and disaster recovery planning.

CHAPTER 2 (INTRODUCTION)

2.1 POLICY PRINCIPLES

The below principles are the essence of the way in which PakTech Medical Systems secures the confidentiality, integrity, and availability of its data and IT systems.

- **Security by Design:**

Security is a fundamental part of all systems and applications and must be built and operated into all initial planning as well as all subsequent systems and applications.

- **Data Protection:**

At all stages of data in transit, data at rest, or data in use, sensitive medical data should be protected from unauthorized access, alteration, loss, or theft.

- **Compliance with Legal and Regulatory Standards:**

The applicable national, and international regulations to be followed by all policies, procedures, and systems are: HIPAA (US based), ISO 27001 and local privacy and data protection laws.

- **Incident Management and Response:**

Fast though security is, it is not fast enough to identify what is occurring on the network as security incidents, report them, and then manage them effectively, which minimizes the impact. In order for an incident response protocol to work, a protocol must be agreed upon that clearly defines roles and responsibilities.

2.2 SECURITY PRINCIPLES

- **Confidentiality:** Ensuring only authorized personnel have access to sensitive data.
- **Integrity:** Guaranteeing that data remains accurate and unaltered unless changed through approved processes.
- **Availability:** Ensuring systems and data remain accessible to authorized users when needed.

2.3 POLICY IMPLEMENTATION

This policy applies to all employees, contractors, consultants, interns, vendors, and third-party service providers who have access to PakTech Medical Systems' IT resources and data. It covers all hardware, software, cloud systems, databases, electronic communications, and information processing devices managed by or on behalf of the

organization. The policy also extends to off-site access and mobile devices used for official purposes.

2.4 POLICY OWNERSHIP

The overall responsibility for this policy lies with the **Information Security Officer (ISO)**, who reports directly to the executive leadership of PakTech Medical Systems. The ISO is responsible for the development, implementation, maintenance, and enforcement of the policy. Department heads and system owners are accountable for ensuring compliance within their areas. The policy shall be reviewed annually or as required due to regulatory or operational changes.

2.5 GUIDING VALUES

ISO 31000 is used as the structure for managing risks when making decisions on security. The most important areas are chosen depending on the value of their assets and the effects they might experience. The organization promptly prevents anyone from accessing its data without permission.

CHAPTER 3 (ROLES AND RESPONSIBILITIES)

3.1 SENIOR MANAGEMENT

It is the Board of Directors and Chief Executive Officer's job to accept and implement the security policy in line with business goals. Enough money and people should be provided by senior management to help put in place and maintain the security strategy. It is also part of their job to show others how to be secure and make sure cybersecurity is a focus in all business activities. They have the ultimate power to enforce rules, take risks and raise the seriousness of critical cases.

3.2 INFORMATION SECURITY OFFICER (ISO)

The security of Pak Tech Medical Systems depends mainly on the Information Security Officer. As part of this job, a minister must design and implement policies, make sure they are followed and adhere to rules set by the country and by other nations. It is up to the ISO to lead response to security incidents, to monitor audits and to conduct standard security assessments. The officer also connects with regulatory bodies required by **Prevention of Electronic Crimes Act (PECA) 2016** and works together with legal counsel to comply with the **Data Protection Act 2018** and **Computer Misuse Act 2019**.

3.3 IT SECURITY TEAM

It is the IT Security Team's job to carry out the technical installation of security systems like set up firewalls, IDS and IPS, endpoint protection applications and handle monitoring with SIEM. Team members need to perform penetration tests often, detect vulnerabilities, resolve found issues and manage documentation on their systems. They must collect, store and review traffic logs as required.

3.4 DEPARTMENT HEADS

Leaders in departments are responsible for applying the security policy to their teams. They review access rights often, make sure staff take required security lessons and inform the ISO about violations or anything suspicious. Heads should evaluate risks that are part of their work and help their departments prepare for audits.

3.5 EMPLOYEES

All employees are required to follow all security policies and procedures all the time. Staff are responsible for using resources properly, avoiding illegal entry into information and informing others immediately if they see a phishing email, suspicious activity or anything unusual. Every year, employees should take part in cybersecurity training and stick to the policies about using the company's systems. Lawful steps such as dismissal and the Computer Misuse Act may take place if a security policy is broken.

CHAPTER 4 (SECURITY CONTROLS)

4.1 ACCESS CONTROL

RBAC should be used at Pak Tech Medical Systems so that each user can only access the data and systems needed for their tasks. This rule requires department heads to approve new accounts and requires the IT team to check accounts regularly. Administrative users must log in with Multi-Factor Authentication. As soon as employees leave, their accounts should be locked immediately to stop them from misusing them. The access rights and uses of privileges will be audited every quarter.

4.2 NETWORK SECURITY

Separating important medical systems (like Electronic Health Records) from the public and general network is done with network segmentation. NGFWs, IDS/IPS and VPNs are often used in external connectivity to protect the network. A security approach known as zero trust is applied which checks and validates every access point and communication.

Normally, rogue devices and unauthorized access points are checked for regularly. SIEM tools monitor traffic information in real time and use it to detect anomalies as required by **ISO 31000** risk treatment strategies.

4.3 CHANGES AND UPDATES TO REGULATIONS

The ISO reserves the authority to make updates to this policy from time to time. Every time a change is made, it needs to be logged through version control and shared with everyone in the organization.

4.4 REPORTING TO ISO AND ESCALATION OPTIONS

Any and all incidents must be communicated to the ISO or security officer immediately. Incidents are handled based on a tiered system depending on how severe they are.

4.5 ACCOUNTIBILITY

Each department must handle its own access records, review risks, and ensure that its own employees are following the rules. If an individual violates any rules, they are held responsible for those actions.

4.6 INFORMATION MANAGING PROCEDURES

All records of access logs, audit trails, policy acknowledgments, and incident reports must be saved for at least 24 months and can be examined during any audit.

CHAPTER 5 (ASSET MANAGEMENT AND IDENTIFICATION)

5.1 ASSET TRACKING PURPOSE AND RELEVANCE

When assets are identified, it will be easy to ensure that all important resources are being monitored, safeguarded and well-maintained. This reduces the chances of losing assets, misconfiguration, and unauthorized access.

5.2 ASSETS INCLUDED IN THE INFORMATION ENVIRONMENT

The major assets included in any given information environment are servers, databases, backup systems, endpoints, software applications, source code, and stores of user credentials.

5.3 DIGITAL ASSETS AND DATA TAXONOMY

Information should be labeled according to levels, e.g., Public, Internal, Confidential, and Restricted. Classification defines the handling procedures and the storage requirements.

5.4 ASSET LABELING

Every asset should be given a distinctive identifier, an owner, a classification tag and be recorded in the asset registry of the organization.

5.5 RISK PROTECTION, ALIGNMENT AND CONTROL

Every asset should have associated security controls which match its risk profile. Multifactor authentication, encryption and around-the-clock monitoring should be applied to high-risk assets.

CHAPTER 6 (COMPLIANCE, INVESTIGATION, AND ENFORCEMENT)

6.1 LEGAL AND REGULATORY COMPLAINECE

The policy is compliant with the Data Protection Act 2018, which promotes lawful processing, storage, and transfer of personal data. It also has controls and prevention strategies under the Computer Misuse Act 2019 against unauthorized system access, interference, or misuse.

6.2 ETHICAL REQUIRMENTS AND INTERNAL COMPLAINECE STANDARDS

Internal codes of conduct, security principles, and operational standards have to be observed by all personnel. Use of systems ethically is a requirement. A violation will be any activity that goes against the integrity standards of the organization.

6.3 INTERNAL AUDIT PRACTICE AND MONITORING PROCEDUERS

Security audits shall be done twice a year. Every department should collaborate and avail requested logs, reports, and records. The audit procedure will also involve evaluating the conformity with ISO 31000 risk management principles.

6.4 DATA BREACH AND INCIDENT RESPONSE

There should be a formal incident response plan that should be adhered to in the event of any security breach. The plan will have the steps of identification, containment, eradication, recovery, and reporting. Organizational procedures must be followed when giving notifications to affected parties.

6.5 RESEARCH PROCEDURES AND INCIDENT ESCALATION PROCESS

It will be mandatory that all the incidents be recorded in the incident register. Investigation shall be initiated within 24hrs and shall entail root cause analysis, collection of evidence, correction and prevention recommendations.

6.6 VERSION CONTROL AND POLICY REVIEW SCHEDULE

Such policy will be reevaluated at least annually or after any significant incident or organizational change in IT infrastructure. Changes should be versioned, documented and archived.

CHAPTER 7 (MISUSE AND PENALTIES FRAMEWORK)

7.1 DEFINITION OF MISUSE

Misuse is any deliberate or careless act of an individual or group that is in breach of the Cybersecurity and Data Protection Policy, but not limited to unauthorized access, tampering of data, privilege misuse, and incident non-reporting.

7.2 TYPES OF VIOLATIONS

1. **Minor Violations:** These include use of weak passwords, accidental policy violation or forgetting to log out of a session.
2. **Moderate Violations:** Unauthorized installation of software, intentional ignorance of policy or circumventing normal process.
3. **Severe Violations:** Gaining unauthorized access to sensitive information, damage of data status, malicious intention, or insider threats, or non-reporting the breach deliberately.

7.3 PENALTY STRUCTURE

- **Minor (e.g. Leaving Systems Unlocked):** Verbal/written warning, re-training.
- **Moderate (e.g. Sharing Passwords):** Formal reprimand, access suspension.
- **Severe (e.g. Data Theft, Sabotage):** Termination, legal prosecution, damages recovery.

7.4 DISCIPLINARY PROCESS

All violations shall be investigated by the Information Security Officer in collaboration with Human Resources. The process should include documentation, review, disciplinary hearing (if needed), and official record entry.

7.5 APPEAL AND RESOLUTION MECHANISM

Employees have the right to appeal disciplinary decisions through a formal review process conducted by senior management. Appeals must be submitted within 7 working days from receipt of disciplinary notice.

7.6 EDUCATION AND PREVENTION

The organization will conduct regular training and simulations to reduce the risk of misuse. All employees are required to acknowledge understanding of the policy and potential penalties as part of onboarding and annual compliance training.